Layer2Meetup@Sydney Meeting Report

- BGIN is a multi-stakeholder discussion body / distributed think tank.

Cybersecurity Information-Sharing

bg in

blockchain
governance
initiative
network

The Global Network for Blockchain Stakeholders™

© 2023 BGIN (Blockchain Governance Initiative Network) is registered as BN Association, a Japanese general association with its principal place of business at Shiba Building, 704, 4-7-6, Shiba, Minato-ku, Tokyo. All rights reserved.

The know-how described in this document was made available from contributions from various sources, including members of the BGIN and others. Although the BGIN has taken steps to help ensure that the know how is available for distribution, it takes no position regarding the validity or scope of any intellectual property or other rights that might be claimed to pertain to the implementation or use of the know how described in this document or the extent to which any license under such rights might or might not be available; neither does it represent that it has made any independent effort to identify any such rights. BGIN and the contributors to this document make no (and hereby expressly disclaim any) warranties (express, implied, or otherwise), including implied warranties of merchantability, non-infringement, fitness for a particular purpose, or title, related to this document, and the entire risk as to implementing this document is assumed by the implementer. The BGIN Intellectual Property Rights policy requires contributors to offer a patent promise not to assert certain patent claims against other contributors and against implementers. BGIN invites any interested party to bring to its attention any copyrights, patents, patent applications, or other proprietary rights that may cover technology that may be required to practice this document.

Layer2 Meetup@Sydney

Keynote Session Report: Cybersecurity Information-Sharing

Date: Wednesday, October 2th, 2024

Location: Sydney

Duration: Approx. 90 minutes

Summary

Comments on the Diagram

Link: https://drive.google.com/file/d/1b705j4mHP1qPXwwij8Hjo-fJJW_k6h3p/view?usp=sharing

- A participant suggests that it should reference broader ISAC structures to ensure it accounts for intelligence exchange beyond the crypto industry. It's suggested that non-crypto sectors, which already monitor cyber threats, should be included.

Crypto ISAC's Role and Function

- A person provides clarity on ISAC's focus, explaining that it's not a standards body but rather one aimed at providing actionable threat intelligence. The goal is to prevent or mitigate blockchain-related security events. He emphasizes that while other organizations release papers or discuss standards, Isaac is more action-oriented in sharing information that helps prevent malicious activity.
- The person describes ISAC as sitting uniquely at the intersection of the public sector, private institutions, and the more anarchic parts of the blockchain industry. This position allows ISAC to facilitate collaboration between different types of entities that may otherwise not communicate with one another.
- The sustainability of ISAC is raised as a concern, with a focus on both financial sustainability and human resources. He explains that ISAC runs on a membership-driven financial model. Membership dues fund ISAC's work, which includes an analyst team that collects and analyzes threat intelligence. He notes that scaling ISAC may require more tools and automation in the future.

Classifying DLT Vulnerabilities

- There's an important discussion, focusing on whether blockchain vulnerabilities are inherent to DLT (Distributed Ledger Technology) itself or if they stem from how the systems are implemented (e.g., on servers or in code). Classifying incidents based on this distinction is suggested.

- Another participant shares another approach, where they focus on cryptographic algorithms rather than vulnerabilities, and discuss the importance of quantum-safe cryptography in DLT systems.

Smart Contract Auditing

- The role of smart contract auditors is discussed. There is a suggestion that information from auditors who often discover and share vulnerabilities could be fed into the framework discussed here. A participant mentions that their country already gathers and categorizes vulnerability information using AI, indicating that similar processes could be adopted globally.

Talent and Education in Web3 Security

- A major point of discussion revolves around the **lack of talent** in Web3 security. A participant mentioned that their country is struggling to recognize the importance of crypto security. The need to introduce courses focused on Web3 security and raise awareness among local security companies about global opportunities in the sector is emphasized.

- It is pointed out that increasing the number of qualified young experts is critical and requires budgeting for educational initiatives. One participant stresses that many startups do not consider security from the outset, and only after attacks occur do they respond. Established industries, like banking, are presented as models to emulate due to their compliance with ISO standards.

Regulatory and Institutional Collaboration

- The CCSS is mentioned, with some debate about its relevance. One participant expresses skepticism about its current effectiveness, noting that it isn't widely used today and may not reflect modern custody systems. A person also contributes to the conversation, agreeing that while CCSS is one of the few Web3 security standards, it may be somewhat static and not reflective of newer developments in the industry.

- Collaboration with regulators and governments is touched upon. Some countries are mentioned as being interested in receiving threat intelligence but reluctant to share their own data. A "big stick" like **PCI DSS** for the credit card industry is seen as a necessary enforcement mechanism for crypto security standards. It's noted that while regulators could enforce compliance with security standards, there is still a gap in terms of documentation and enforcement across the industry.

- Toward the end, there's a deeper discussion of **BGIN's** role. Participants explore how BGIN could create standards, comparing it to **ISO**. Unlike ISO, which is described as exclusive and slow to respond, BGIN is seen as open and agile. However, it is acknowledged that BGIN's standards would still need to be formalized in organizations like ISO to be widely adopted.

- One participant suggests that BGIN could play a role similar to **IETF** (the Internet Engineering Task Force), where it develops smaller, more agile standards, while other bodies like Isaac could help enforce them. The participant notes that ISO standards take at least two years to create, which may be too slow to address emerging vulnerabilities.